

Couche Transport et Sécurité Web (SSL / TLS)

Sécurité Web

- ▶ HTTP n'est pas un protocole sécurisé
 - ▶ simple application client / serveur fonctionnant sur TCP / IP
- ▶ Ajout de mesures de sécurité nécessaires
 - ▶ nous verrons SSL (Secure Socket Layer) et TLS (Transport Layer Security)
 - ▶ HTTPS
 - ▶ Protocole HTTP sécurisé
- ▶ En fait, le support SSL est également fourni pour plusieurs autres applications TCP / IP
 - ▶ POP3, SMTP, FTP, ...

Sécurité Web

3

Portée de SSL / TLS

► Menaces et contre-mesures

► Intégrité

- modification de données, insertion
 - sommes de contrôle cryptographiques (HMAC)

► Confidentialité

- écoute clandestine sur le réseau
 - peut être empêché par le cryptage
- vol de la machine serveur
 - SSL peut résoudre dans une certaine mesure,
 - mais des mesures de sécurité sur site sont toujours nécessaires

► Authentification

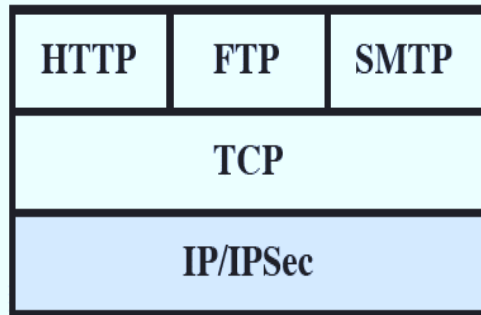
- usurpation d'identité, falsification de données
- techniques cryptographiques

► Dénî de service, serveurs Web piratés

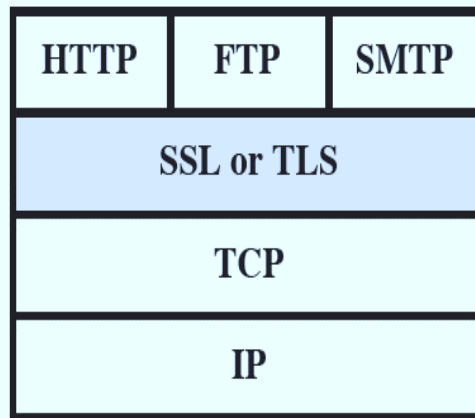
Où assurer la sécurité?

4

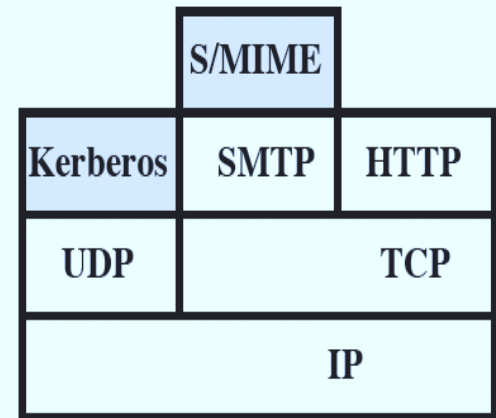
- Situation respective des dispositifs de sécurité dans la pile de protocoles TCP/IP



(a) Network Level



(b) Transport Level



(c) Application Level

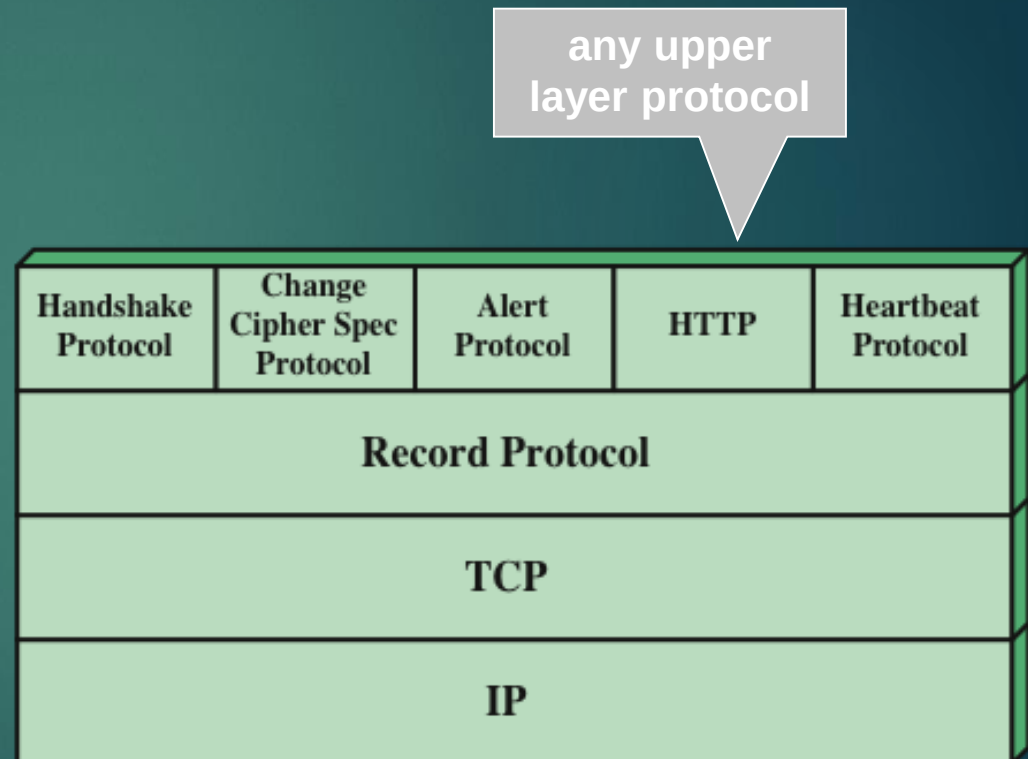
SSL (Secure Socket Layer)

- ▶ développé à l'origine par Netscape
- ▶ version 3 conçue avec la participation du public
- ▶ par la suite, l'effort de normalisation d'Internet a commencé à l'IETF
 - ▶ Création du groupe de travail TLS (Transport Layer Security)
 - ▶ TLS peut être considéré comme SSL v3.1 et compatible avec SSL v3

Pile de protocoles TLS

6

- **utilise TCP** (transfert de données fiable de bout en bout)
- ▶ **Ajoute des fonctionnalités de sécurité**
 - ▶ transfert de données fiable et sécurisé de bout en bout
- ▶ **TLS n'est pas un protocole unique**
 - ▶ deux couches de protocoles



Deux concepts TLS

▶ Session TLS

- ▶ une association entre client et serveur
- ▶ Pour définir un ensemble de paramètres cryptographiques
- ▶ ensemble qui peut être partagé par plusieurs connexions TLS
- ▶ Les sessions sont créés par le protocole Handshake

▶ Connexion TLS

- ▶ un lien de communication entre homologues, temporaire, et sécurisé
- ▶ associé à une session TLS
- ▶ Une session est utilisée plusieurs fois pour créer des connexions

▶ Session vs connexion

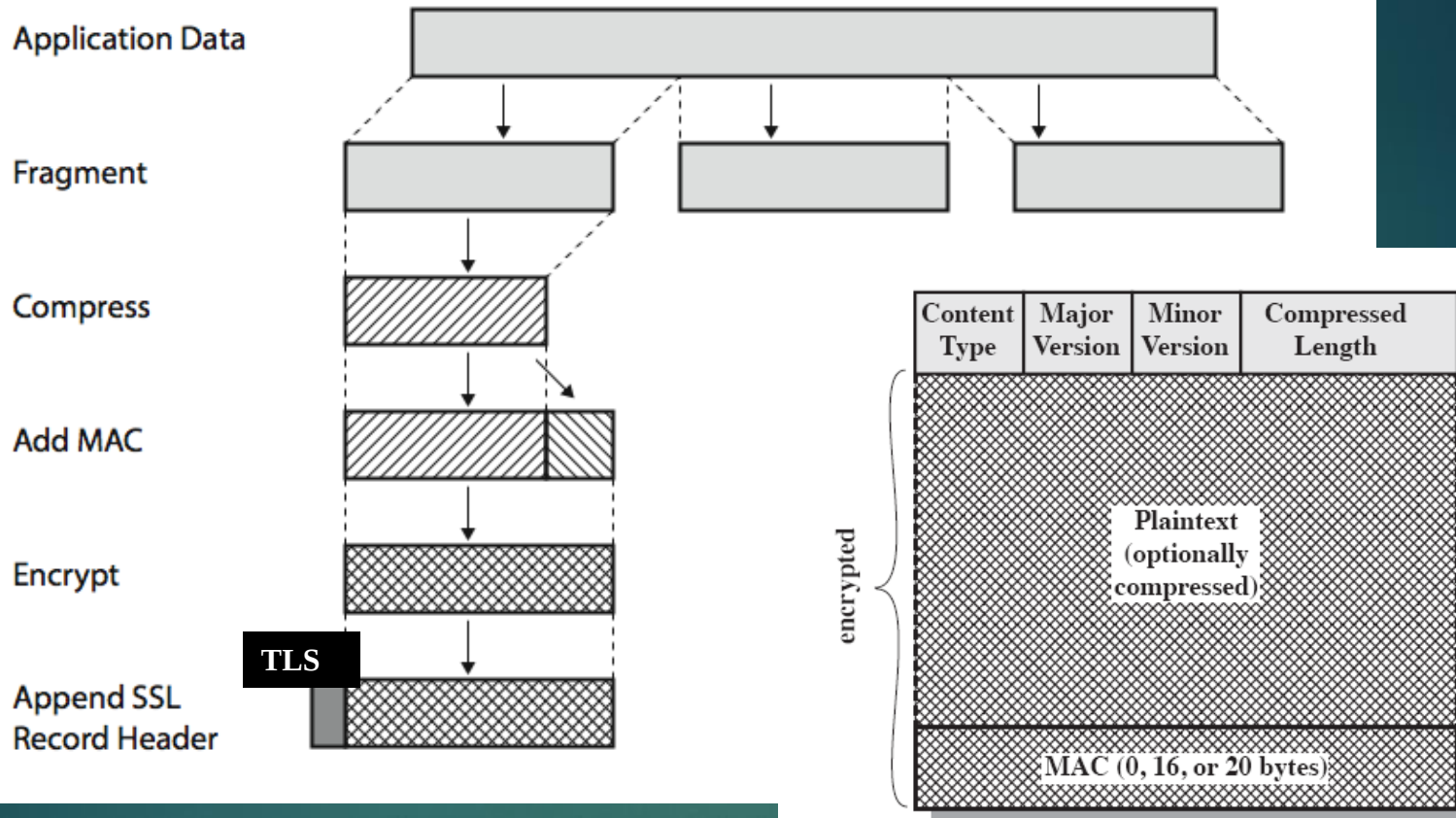
- ▶ Les sessions sont utilisées pour éviter une négociation coûteuse pour les paramètres cryptographiques pour chaque connexion
- ▶ Les deux sont caractérisés par plusieurs paramètres
 - ▶ qui définissent un état de session ou un état de connexion

TLS Record Protocol

- ▶ Fournit deux services pour les connexions TLS
 - ▶ Confidentialité et Intégrité
 - ▶ utilise les paramètres de connexion
- ▶ assure la confidentialité et l'intégrité
- ▶ également la fragmentation (découpage du message en morceaux de 2^{14} octets)
- ▶ compresse éventuellement les données (en pratique, pas de compression et ceci est déconseillé dans la dernière version de TLS)
- ▶ confidentialité
 - ▶ AES, IDEA, DES, 3DES, RC4, etc.
- ▶ intégrité du message
 - ▶ en utilisant HMAC avec une clé secrète partagée
- ▶ Avec SSL, la méthode était similaire à HMAC mais les tampons étaient concaténés plutôt que XOR

TLS Record Protocol

9



Ajout de champs d'en-tête

- ▶ **type de contenu** (protocole de couche supérieure)
 - ▶ change_cipher_spec, alerte, Handshake, données d'application
- ▶ **version**
- ▶ **longueur compressée** (ou longueur en clair si aucune compression) du fragment

Change Cipher Spec Protocol

10

- ▶ Protocole de changement de spécification de chiffrement
- ▶ protocole très simple
 - ▶ Consiste en un message unique (1 octet de valeur 1)
- ▶ fait en sorte que l'état transitoire soit copié dans l'état actuel
 - ▶ modifier le protocole de spécification de chiffrement (met à jour le chiffrement à employer pour une nouvelle connexion)
 - ▶ les paramètres de connexion changent après cela
- ▶ Nous verrons son utilisation dans le protocole de prise de contact (Handshake Protocol)

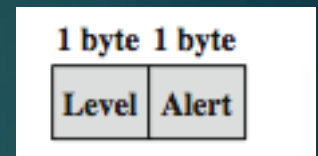


Change Cipher Spec
Protocol

Alert Protocol

11

- ▶ transmet les alertes TLS à l'entité homologue
- ▶ sécurisé à l'aide du record protocol (le cas échéant)
 - ▶ avec les paramètres actuels de l'état de connexion
- ▶ chaque message est de deux octets
 - ▶ un octet pour le niveau (gravité)
 - ▶ avertissement (la connexion peut reprendre) ou fatale (la connexion est interrompue)
 - ▶ un octet pour le code d'alerte
 - ▶ **Alertes fatales** : message inattendu, mauvais enregistrement MAC, échec de décompression, échec de la poignée de main (pas de terrain d'entente), paramètres illégaux (paramètres incohérents ou non reconnus)
 - ▶ **Autres alertes** : aucun certificat, certificat incorrect, certificat non pris en charge, certificat révoqué, certificat expiré, certificat inconnu



Alert Protocol

Handshake Protocol

12

- ▶ La partie la plus complexe de TLS
- ▶ Permet au serveur et au client :
 - ▶ de s'authentifier
 - ▶ pour négocier le cryptage et les algorithmes MAC
 - ▶ pour créer des clés cryptographiques à utiliser
 - ▶ en général, pour établir une session puis une connexion
- ▶ la prise de contact est effectuée avant la transmission des données
 - ▶ ne peut donc pas assumer Record Protocol sécurisé

Handshake Protocol

13

► une série de messages en 4 phases

1. Établir des capacités de sécurité
2. Authentification du serveur et échange de clés
3. Authentification du client et échange de clés
4. terminer

≥

► Format de message Handshake

► Types de messages

1 byte	3 bytes	0 bytes
Type	Length	Content

Message Type	Parameters
hello_request	null
client_hello	version, random, session id, cipher suite, compression method
server_hello	version, random, session id, cipher suite, compression method
certificate	chain of X.509v3 certificates
server_key_exchange	parameters, signature
certificate_request	type, authorities
server_done	null
certificate_verify	signature
client_key_exchange	parameters, signature
finished	hash value

Handshake Protocol

